

INFORME DE GESTIÓN DE INCIDENTES DE SEGURIDAD (ISO/IEC 27001).

Informe de Incidente: Explotación de Vulnerabilidad de Inyección SQL en Aplicación Web Crítica (DVWA).

- **Incidente:** Explotación de Vulnerabilidad SQL Injection, en Entorno Controlado.
- **Normativa de Referencia:** Alineado con los controles de gestión de incidentes y desarrollo seguro de la norma **ISO/IEC 27001**.
- **Autor:** Jair Andre Vásquez Gómez

Este informe documenta la identificación, explotación y análisis de un incidente de seguridad de la información detectado en los sistemas de la organización, de acuerdo con los lineamientos del Anexo A.16 (Gestión de Incidentes de Seguridad de la Información) de la norma ISO 27001.

El incidente involucra la explotación exitosa de una vulnerabilidad de Inyección SQL (SQLi) en el entorno web corporativo. El propósito de este documento es registrar la evidencia técnica, evaluar el impacto sobre la infraestructura afectada y proponer las acciones correctivas inmediatas para mitigar el riesgo y asegurar el cumplimiento de las políticas de seguridad.

Durante una auditoría de seguridad programada en nuestro laboratorio de pruebas, se detectó una vulnerabilidad de severidad alta en la aplicación web Damn Vulnerable Web Application (DVWA), la cual se encuentra alojada en un servidor web Apache sobre una máquina virtual Debian.

Un atacante simulado, utilizando una máquina auditora Kali Linux, logró evadir los mecanismos de autenticación y lógica de consultas de la aplicación. Al no contar el sistema con una debida sanitización de los datos de entrada en el formulario de búsqueda de usuarios, el atacante logró inyectar código SQL malicioso, forzando a la base de datos subyacente (MariaDB/MySQL) a ejecutar comandos no autorizados y exponer registros protegidos.

Proceso de Reproducción:

Para validar y auditar el incidente, se procedió a reproducir el ataque bajo un entorno controlado utilizando las siguientes fases técnicas:

1. **Fase de Acceso:** Desde la máquina atacante (Kali Linux), se accedió mediante el navegador web a la dirección IP de la máquina víctima (Debian) donde corre el servicio: `http://http://192.168.0.192/DVWA`.
2. **Autenticación inicial:** Se inició sesión en el portal con las credenciales por defecto (admin / password) y se constató que el nivel de seguridad de la aplicación web se encontraba configurado en "Low".
3. **Inyección del Payload:** Se navegó hasta el módulo crítico de SQL Injection. En el campo de texto destinado para ingresar el User ID, se introdujo el siguiente vector de ataque diseñado para romper la lógica de la consulta SQL:

```
1' OR '1'='1
```

Ejecución y Resultados:

Al hacer clic en el botón "Submit", la aplicación web procesó el input directamente en la base de datos sin aplicar filtros. Dado que la condición `'1'='1'` siempre es verdadera, la consulta del sistema saltó la restricción del ID y devolvió la totalidad de las filas existentes en la tabla de usuarios.

Impacto del Incidente:

De acuerdo con los criterios de evaluación de riesgos de la norma ISO 27001, el impacto de este incidente se clasifica como “ALTO” debido a la afectación directa de la tríada.

CID: Confidencialidad, integridad y disponibilidad.

- **Confidencialidad (Compromiso TOTAL):** El impacto principal radica aquí. Al ejecutarse la inyección de manera exitosa, el atacante obtuvo visibilidad completa de la base de datos de usuarios (nombres, apellidos y hashes de contraseñas de cuentas.). Se ha producido una filtración de datos no autorizada.
- **Integridad (Compromiso PARCIAL/POTENCIAL):** Aunque en este ejercicio se realizó una consulta de lectura, un atacante con mayores privilegios podría utilizar técnicas similares para alterar, modificar o borrar registros o inyectar scripts maliciosos.
- **Disponibilidad (Compromiso POTENCIAL):** Dependiendo de la consulta inyectada, se podrían realizar ataques de denegación de servicio a la base de datos utilizando funciones de retardo de tiempo, saturando el servidor web Debian.

Recomendaciones:

Para dar cumplimiento a los controles de mitigación exigidos por la ISO 27001, se recomienda aplicar de manera urgente las siguientes medidas correctivas en el código de la aplicación:

- **Implementación de Consultas Preparadas:** Se debe reescribir el código PHP de la aplicación para utilizar la extensión PDO o MySQLi con sentencias parametrizadas. Esto garantiza que el input del usuario (`'1' OR '1'='1'`) se trate estrictamente como un dato (un string) y nunca como código ejecutable por el motor de la base de datos.
- **Sanitización y Validación de Entradas:** Implementar funciones de filtrado estricto (`filter_var()`) que rechacen cualquier carácter especial (como comillas simples ``` o guiones `--`) que no corresponda al formato esperado (en este caso, un número entero para el ID).
- **Principio de Menor Privilegio:** Modificar la configuración del archivo `config.inc.php` analizado en la instalación para que la aplicación web no se conecte a la base de datos utilizando el usuario `root`. Se debe crear un usuario específico con permisos limitados exclusivamente a las tablas que necesita operar.

Conclusión:

- La explotación exitosa de la inyección SQL entre nuestras máquinas virtuales Kali Linux y Debian pone de manifiesto una falta de controles de seguridad en la capa de desarrollo de la aplicación web. El incidente demuestra que la ausencia de validación en los inputs de los usuarios representa un riesgo crítico para la confidencialidad de la información organizativa.
- La incorporación inmediata de las recomendaciones técnicas propuestas, sumada a auditorías de código periódicas, permitirá alinear el sistema con los estándares de seguridad de la norma ISO 27001, cerrando esta brecha y previniendo futuros accesos no autorizados.

Fotografía de la demostración de la incidencia:

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'= '1
First name: admin
Surname: admin

ID: 1' OR '1'= '1
First name: Gordon
Surname: Brown

ID: 1' OR '1'= '1
First name: Hack
Surname: Me

ID: 1' OR '1'= '1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'= '1
First name: Bob
Surname: Smith